Segurança em Sistemas Operacionais e Redes – II

FootPrinting

O que é Footprinting

- Técnica usada para reunir o máximo de dados possível sobre um alvo **(Sistema de Computador Específico, uma infraestrutura de rede).**
- Um dos melhores métodos para encontrar vulnerabilidades.

Informações Alvo

- S.O utilizado
- Firewalls no ambiente e qual marca e modelo.
- Mapas, topologia de rede.
- Endereço IP.
- Informações do sistema de nomes de domínio – DNS.
- Configurações de segurança da máquina.
- URLs,
- Redes privadas virtuais.
- Ids de funcionários.
- Endereços de Emails.

Tipos

- Existem dois tipos de footprinting:
  - **Active Footprinting:** Descreve o processo de usar ferramentas técnicas, como os comandos traceroute ou ping sweep para coletar informações sobre o alvo.
  - **Passive Footprinting:** Envolve a coleta de dados sobre um alvo usando métodos inócuos, como realizar uma pesquisa no Google, procurar no Archive.org, usar o NeoTrace, navegar pelos perfis de mídia social dos funcionários, usar o Whois (nomes de domínios).
    Uma abordagem mais furtiva, não aciona as proteções do ambiente como o IDS/IPS.

Identificar e Conhecer o Alvo

- No site buscar as principais informações:
  - Email, Telefone, referências a outros sites
- Verificar o código fonte da página e buscar por informações relevantes.
- Enumeração DNS (http://who.is), pelo terminal do Kali. #whois onomedosite
- Sendo um domínio .br, utilizar o registro.br

Identificar e Conhecer o Alvo

- Procurar por IPs e IPs da aplicação
  - ping nomedosite
  - host nomedosite
- Verificar se tem IDS/IPS ou Firewall WAF.
  - No Kali utilizar o wafwoof http://nomedosite
- Buscar mais informações via DNS
  - dnsenum domínio (cancelar o brute force no final)

Identificar e Conhecer o Alvo

- Buscar por subdomínios.
  - Utilizar o site crt.sh e colocar o nome do domínio
- Podemos utilizar também brute force de domínio.
  - dnsrecon –d domínio.com –t brt
  - dnsenum domínio.com –f /usr/share/wordlists/wfuzz/general/common.txt
- Podemos utilizar Google Hacking
  - Digitar na pesquisa do google site:onomedosite.com

Identificar e Conhecer o Alvo

- Podemos também procurar por configurações no site que nos ofereça informação.
  - www.nomedosite.com/robots.txt

(Um arquivo robots.txt é um conjunto de diretrizes para bots. Este arquivo está incluído nos arquivos de origem da maioria dos sites. Os arquivos robots.txt destinam-se à gestão das atividades de bots, como web crawlers, embora nem todos os bots sigam as instruções).

Hugo Rebello

hugo.rebello@fatec.sp.gov.br